

Esquema de Seguridad

1. Identificación y Autenticación

El sistema utiliza el RUT como identificador único de cada usuario, dado que el Sistema Gubernamental (Registro Civil) ya posee la información personal de los pacientes y es la fuente autoritativa de identidad.

La autenticación se realiza en tres pasos sucesivos:

Proceso de autenticación

- **Paso 1 — Verificación de identidad:** el backend consulta al Sistema Gubernamental enviando el RUT y la credencial del usuario. Si la identidad es válida, se reciben los datos personales de la persona.
- **Paso 2 — Asignación de rol:** el backend consulta la base de datos interna para obtener el rol asociado a ese RUT (paciente, vacunador o coordinador). Si el RUT no existe con un rol asignado, el acceso es denegado.
- **Paso 3 — Emisión de token:** el Controlador de Seguridad genera un JWT firmado que contiene el RUT, el rol y el tiempo de expiración. Este token es retornado al cliente por sobre una conexión HTTPS.

Mecanismo de token: El sistema emite un JWT (JSON Web Token) firmado con algoritmo HS256 y una clave secreta almacenada únicamente en el backend. El token incluye como claims el RUT del usuario (campo *sub*), el rol asignado, el nombre del usuario, la fecha de emisión y la fecha de expiración (24 horas). El cliente nunca tiene acceso a la clave de firma. Toda comunicación entre el frontend Flutter y el backend ocurre sobre HTTPS.

2. Manejo de Sesión

El sistema adopta un modelo de sesión sin estado (stateless) basado en JWT. No se almacena estado de sesión en el servidor: cada solicitud del cliente incluye el token en el encabezado HTTP y el Controlador de Seguridad lo valida antes de procesar cualquier operación.

Parámetro	Descripción
Duración de sesión	24 horas, codificadas en el claim exp del JWT. Al expirar, el usuario debe volver a iniciar sesión.
Almacenamiento cliente	El token se guarda en flutter_secure_storage, que cifra el contenido usando el llavero seguro del sistema operativo.

Transmisión	Se incluye en cada solicitud mediante el encabezado Authorization: Bearer <token>. Nunca se expone en la URL ni en cookies.
Cierre de sesión	El token se elimina del almacenamiento local del dispositivo. El servidor no mantiene lista negra (limitación del prototipo).
Respuestas de error	Token inválido o expirado devuelve 401 Unauthorized. Rol insuficiente devuelve 403 Forbidden.

Nota: *El servidor no mantiene una lista negra de tokens por simplicidad del prototipo. En un entorno de producción se debería implementar un mecanismo de revocación para invalidar tokens antes de su expiración (por ejemplo, mediante Redis o cambio de clave de firma por usuario).*

3. Distinción de Roles

El sistema define cuatro roles con distintos niveles de privilegio. El rol queda codificado dentro del JWT en el claim rol y es verificado por el middleware en cada operación. No es posible elevarse a un rol superior sin una reasignación explícita en la base de datos por parte del equipo técnico.

Rol	Nombre en sistema	Descripción y alcance
Persona Usaria	<i>paciente</i>	Ciudadano que va a ser vacunado. Puede ver sus propias citas y su historial de vacunación. No puede acceder a información de otros pacientes.
Personal de Vacunación	<i>vacunador</i>	Encargado de aplicar vacunas y registrar el acto de vacunación. Puede buscar pacientes por RUT y registrar vacunaciones en su centro asignado.
Coordinador de Centro	<i>coordinador</i>	Gestiona las citas del centro de vacunación que le fue asignado. Puede asignar turnos y consultar el avance. No puede operar sobre otros centros.
Admin de Campaña	<i>admin</i>	Acceso completo para crear, modificar y supervisar campañas a nivel nacional. Solo puede ser asignado directamente en la base de datos por el equipo técnico.

4. Control de Acceso por Rol (RBAC)

El Controlador de Seguridad implementa control de acceso basado en roles (RBAC). Cada endpoint del backend declara explícitamente qué roles pueden acceder a él. El middleware

extrae el claim rol del JWT y verifica si corresponde a un rol autorizado antes de ejecutar la lógica del controlador correspondiente.

Operación	Paciente	Vacunador	Coordinador	Admin
Ver mis citas y próximas vacunas	✓	—	—	✓
Ver mi historial de vacunación	✓	—	—	✓
Buscar paciente por RUT	—	✓	✓	✓
Registrar vacunación	—	✓	—	✓
Gestionar citas del centro asignado	—	—	✓ (solo propio)	✓
Ver centros de vacunación	✓	✓	✓	✓
Modificar datos del centro	—	—	✓ (solo propio)	✓
Crear / modificar campaña de vacunación	—	—	—	✓
Consultar avance de campaña (agregado)	—	—	✓	✓

Nota: El Coordinador solo puede operar sobre el centro al que está asignado. Esta restricción se implementa no solo verificando el rol, sino también comparando el identificador de centro del token con el recurso solicitado).

5. Secuencia de Autenticación

A continuación, se describe el flujo completo de autenticación y el control de acceso en una operación protegida. El Controlador de Seguridad actúa como middleware entre el frontend y todos los controladores internos del backend.

Fase 1 — Login (autenticación inicial)

Flujo de autenticación paso a paso:

- **1:** El usuario ingresa su RUT y contraseña en el frontend Flutter.
- **2:** El frontend envía una solicitud POST /auth/login al backend por HTTPS.
- **3:** El backend consulta al Sistema Gubernamental para verificar la identidad del RUT. Si falla, retorna 401 Unauthorized.
- **4:** Si la identidad es válida, el backend consulta en la base de datos el rol asociado a ese RUT.

- **5:** El Controlador de Seguridad genera un JWT firmado con el RUT, el rol, el nombre y la expiración (24h).
- **6:** El token es retornado al frontend, que lo almacena en flutter_secure_storage.

Fase 2 — Operación protegida

Flujo de validación en cada solicitud posterior:

- **1:** El frontend incluye el JWT en el encabezado Authorization: Bearer <token> de cada solicitud.
- **2:** El Controlador de Seguridad intercepta la solicitud, verifica la firma del JWT y comprueba que no haya expirado.
- **3:** Si el token es inválido o expirado, se retorna 403 Forbidden sin continuar el procesamiento.
- **4:** Si el token es válido, se extraen los claims (RUT y rol) para verificar el control de acceso.
- **5:** Si el rol es suficiente para la operación solicitada, se ejecuta la lógica del controlador correspondiente.
- **6:** Si el rol no es suficiente, se retorna 403 Forbidden.
- **7:** Para operaciones sensibles (como registrar vacunación), también se verifica que el recurso pertenezca al mismo centro que el usuario autenticado.

6. Protección de Operaciones según Rol Autenticado

El Controlador de Seguridad, visible como componente en el diagrama C4 de componentes, centraliza la lógica de autorización y actúa como middleware para todos los controladores internos: Controlador de Citas, Controlador de Vacunas, Controlador de Centros y Controlador de Campañas. Ningún controlador puede ser invocado directamente sin pasar antes por la validación de seguridad.

Reglas de protección implementadas:

- **Control fino por recurso — Paciente:** el claim sub (RUT) del JWT es comparado con el RUT del recurso solicitado. Un paciente solo puede ver su propia información, aunque tenga un token válido.
- **Control fino por recurso — Vacunador:** solo puede registrar vacunaciones en el centro asignado, verificando que el identificador de centro del token coincida con el de la cita.
- **Control fino por recurso — Coordinador:** las operaciones de escritura sobre Centros y Citas son filtradas por el identificador de centro del token.
- **Restricción del Administrador:** el administrador de campaña no puede acceder a historiales médicos individuales de pacientes; solo opera sobre campañas y métricas agregadas de avance.
- **Trazabilidad de auditoría:** toda operación sensible queda registrada en la base de datos junto con el RUT del usuario autenticado, permitiendo verificar quién realizó cada acción y cuándo.

Gracias a que el Controlador de Seguridad está separado del resto de la lógica de negocio, la política de acceso puede modificarse en un solo lugar sin afectar a los demás controladores, lo que favorece la mantenibilidad y la trazabilidad del diseño de seguridad.